

05 — Data map (what the app holds, where, who touches it, how long)

Pulled from the code on 6 October 2026. "Business" = the painting business that holds the account. "We" = Paint Trade HQ.

1. Categories of personal information

Category	About whom	Entered by	Examples
Account holder	Business owner, office team	Themselves	Name, email (sign-in), mobile, hashed password, Terms version + acceptance time + IP, tester access code, sign-in times and devices
Business profile	The business	Owner	Trading name, ABN, address, licence number, logo, signature image, bank details, Google review link, quote/invoice/contract wording
Crew	Employees	Owner and the employee (onboarding)	Name, contact details, address, emergency contact, date of birth, pay rate, award classification, licences/qualifications with uploaded copies, employment documents and signatures, timesheets, sign-in GPS positions and off-site flags, leave, strikes/recognition, training progress, equipment issued, performance ratings, profile photo
Clients and leads	The business's customers	Owner/team	Name, company, phone, email, site and postal address, source, notes, tags, call/message history, quotes, invoices, payments, projects, review and follow-up preferences, SMS opt-out
Other contacts	A client's additional contacts	Owner/team	Name, role, email, phone, "gets quotes / gets invoices" flags
Job records	Clients' properties	Owner/team/crew	Measurements, prices, site photos and before/after photos (with mark-ups), daily reports, variations with approver name/time/IP, completion reports
Messages	Clients, crew	Business (sent), clients (received)	Email and SMS sent and received through the app, including via a connected Gmail / Microsoft 365 / IMAP inbox and a connected Twilio number
Public-link activity	Clients	Automatic	Time, IP address and browser when a quote/invoice/variation/report link is opened; accepted/declined/paid
Quote acceptance	Clients	The client	Signer name, signature image, time, IP, options chosen

Category	About whom	Entered by	Examples
Payments	Clients	Business	Bank-transfer / cash / card-in-person / cheque payments as the business records them (no card data)
Connected services	The business	Owner	OAuth tokens for Google Drive/Calendar/Gmail, Microsoft 365 (OneDrive, Outlook calendar, mail), IMAP credentials, Apple iCloud app-specific password (encrypted at rest), Twilio credentials
AI	The business	Automatic / owner	Prompts and responses for drafts and the morning brief; reminders and ideas the owner gives Lucy; per-business audit log of AI calls and daily usage
Tester program	Testers (owners)	Testers	Feedback messages and screenshots sent through the in-app helper, sign-up leads, invite codes, failed-code attempts
Product updates	All users	Automatic	Which "what's new" updates a user has seen or snoozed
Technical	All users	Automatic	Error reports (page, error text, browser), request timing logs (route, duration, business id), security/rate-limit logs

2. Where it is stored

Data	Where
Everything above except files	MongoDB database on the Emergent hosting platform (region: Josh to confirm)
Photos, attachments, staff documents, signatures, PDFs	Built-in store (today: inside the database as encoded data; a Google Cloud Storage bucket is planned before testers upload real photos), or the business's own Google Drive , or the business's own Microsoft OneDrive — the business chooses in Settings. Staff documents and signature images are always private (never a public link). Photos in Drive/OneDrive are set to "anyone with the link can view" so they can be shown on client links
Browser	Sign-in token, role and a few display preferences in local storage; no advertising cookies

3. Third parties that process personal information

Provider	What for	Data sent	Where	When
Emergent	Hosting (servers, database)	Everything	Region to confirm	Always (until the move to own hosting)
Resend	Sending email	Recipient address, subject, body, PDF attachments	United States	Every email the app sends

Provider	What for	Data sent	Where	When
Twilio	SMS sending and receiving	Phone numbers, message text	United States	Only when the business connects a Twilio number
Anthropic (Claude API)	AI drafts, morning brief, assistant	Parts of the business's own data: today's jobs, recent quotes, a client's message history, text to polish; the owner's reminders/ideas	United States	Under the business owner's own API key; Anthropic's commercial terms: not used for training
Open-Meteo	Weather for the brief; geocoding job addresses	Job suburb/address coordinates	Germany (EU)	Daily brief; when an address is saved
Google	Drive storage, Calendar overlay, Gmail inbox sync	Photos/files; calendar events; emails	Global	Only when the business connects them
Microsoft	OneDrive storage, Outlook calendar, Microsoft 365 mail	Photos/files; calendar events; emails	Global	Only when the business connects them
Apple	iCloud calendar overlay	Calendar events	Global	Only when the business connects it
Stripe	Our subscription billing (later)	Owner's card details (held by Stripe, not us)	US/Australia	Not yet
marker.js (library)	Photo mark-up tool in the browser	None leaves the browser	—	—

No advertising or analytics trackers.

4. Retention today

Data	Kept
Everything in an open account	While the account is open
Archived items (quotes, clients, projects, reports, ratings)	Soft-deleted ("archived") and restorable; a nightly job reports what is older than 30 days but does not yet delete it (the 30-day hard purge is planned)
Closed accounts	Policy says 30 days then deletion, backups within a further 60 days — not automated yet
Employment documents, signatures, signed PDFs	At least 7 years, treated as records

Data	Kept
Quote/invoice/variation acceptance records and events	With the document (never edited or hard-deleted)
Public-link activity, error reports, security logs	Policy says up to 12 months; no automated trim yet
AI audit log and cached briefs	Kept per business; no trim yet
Tester feedback	Kept by the platform admin; exported for development

5. Who can see what

- A business's admin users: everything in their workspace. Team members can be limited per module (customisable team access).
- Crew: their own records, documents, timesheets, the jobs they are assigned, the crew-side training and equipment screens. No AI.
- Clients: only their own quote/invoice/variation/report pages via the links.
- The Paint Trade HQ platform administrator (Josh): tester invites, sign-up leads, tester feedback, product updates across all businesses. Not the businesses' client or job data through the app (the hosting provider's database is accessible to the operator for support and backups).
- Tenant separation is tested automatically on every release.